

Phishing Awareness Analysis

Project 3 — Industrial Training Kit

Cybersecurity Analyst Intern
DecodeLabs

July 20, 2026

1 Introduction

The modern cybersecurity perimeter is no longer just the network firewall — it is the user. This project focuses on **threat identification**: analyzing sample emails and messages to detect phishing attempts, list the red flags present, and determine the correct response action.

Statistics show that approximately 80% of security breaches involve phishing, and it takes an attacker an average of only 82 seconds to get their first click once a phishing campaign begins. This makes human awareness just as critical as technical defenses.

2 Methodology

Each sample message below is analyzed using the following framework:

1. Identify the sender and check for domain/display-name mismatches.
2. Detect psychological triggers (Authority, Urgency, Curiosity, Fear/Greed).
3. List technical red flags (spoofed domains, suspicious attachments, credential requests).
4. Assign a final verdict: **Safe**, **Suspicious**, or **Malicious**.

3 Sample Analysis

3.1 Sample 1: Urgent Password Expiry Email

Email Sample

From: IT Security Team <support@login-secure-updates.net>

Subject: ⚠ URGENT: Your Password Expires in 24 Hours

Dear User, our system has detected that your password will expire in 24 hours. To avoid losing access, please verify your credentials immediately using the secure link below. Failure to act within 24 hours will result in permanent account suspension.

Red Flags Identified:

- Sender-domain mismatch — claims "IT Security" but domain is unrelated to the real company.
- Urgency trigger — artificial 24-hour countdown.
- Fear trigger — threat of permanent account suspension.

- Generic greeting ("Dear User") instead of the recipient's actual name.

Why It Is Unsafe: This is a credential harvesting attempt. Clicking the link leads to a fake login page designed to steal the user's real password.

Verdict: **Malicious — Block domain & escalate to IT**

3.2 Sample 2: CEO Wire Transfer Request (Business Email Compromise)

Email Sample

From: John Smith - CEO <john.smith@yourcompany-finance.com>

Subject: Urgent Wire Transfer — Confidential

I'm currently in a closed-door meeting and can't take calls. I need you to process an urgent wire transfer of \$45,000 to our new vendor before end of day. Please keep this confidential for now.

Red Flags Identified:

- Domain mismatch — real CEO domain is @yourcompany.com, not a combosquatted lookalike.
- Authority trigger — impersonating the CEO to demand compliance.
- Urgent bypass request — secrecy and time pressure prevent normal verification.
- No prior context or approval trail for a transfer of this size.

Why It Is Unsafe: This is a classic Business Email Compromise (BEC) attack. The "can't take calls" detail is specifically designed to block the verification step that would expose the fraud.

Verdict: **Malicious — Block & escalate; do not process the transfer**

3.3 Sample 3: Suspicious Login Alert (Borderline Case)

Email Sample

From: Microsoft Account Team <account-security@microsoft.com>

Subject: New sign-in to your Microsoft account

We noticed a new sign-in to your Microsoft account from Lahore, Pakistan. If this was you, no action is needed. If you don't recognize this activity, please review your recent activity.

Observations:

- Domain appears legitimate, but headers can still be spoofed even when the visible domain matches.
- No urgent countdown or explicit threat — calmer tone than a typical attack.
- Best practice regardless: never click the embedded button; navigate to the account portal manually.

Why Caution Still Applies: Even legitimate-looking alerts should be verified independently, since sender information can be forged convincingly.

Verdict: **Suspicious — Warn user to verify independently; avoid clicking**

4 Triage Decision Tree

SAFE	SUSPICIOUS	MALICIOUS
Matches known sender, no red flags found	Some red flags present, intent unclear	Confirmed fake domain, credential harvesting, or fraud
↓	↓	↓
Close (no action needed)	Warn User (advise manual verification)	Block & Escalate (report to security team)

5 Non-Expert Triage Checklist

Does the sender's actual email domain match who they claim to be?

Is there urgency, fear, or pressure to act immediately?

Is it asking for a password, MFA code, or payment details over email?

Are there unusual attachments (.iso, .js, .scr) or mismatched links?

Is it asking to bypass normal procedure or keep something secret?

Can this be verified through a different channel (phone call, in person)?

If any box is checked and independent verification is not possible, treat the message as suspicious at minimum and report it.

6 Conclusion

Phishing exploits the gap between technical controls and human reaction. By mastering threat identification, recognizing psychological manipulation tactics, and applying a consistent Pause–Verify–Report process, this analysis directly strengthens the "human firewall" that technical systems alone cannot provide.